

1. Denial-of-service (DoS) and distributed denial-of-service (DDoS) attacks

A denial-of-service attack overwhelms a system's resources so that it cannot respond to service requests. A DDoS attack is also an attack on system's resources, but it is launched from a large number of other host machines that are infected by malicious software controlled by the attacker.

Unlike attacks that are designed to enable the attacker to gain or increase access, denial-of-service doesn't provide direct benefits for attackers. For some of them, it's enough to have the satisfaction of service denial. However, if the attacked resource belongs to a business competitor, then the benefit to the attacker may be real enough. Another purpose of a DoS attack can be to take a system offline so that a different kind of attack can be launched. One common example is session hijacking, which I'll describe later.

There are different types of DoS and DDoS attacks; the most common are TCP SYN flood attack, teardrop attack, smurf attack, ping-of-death attack and botnets.

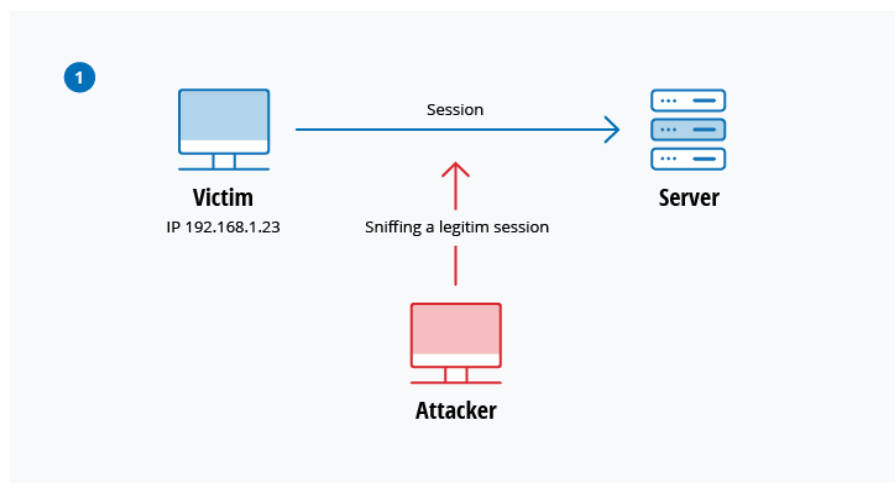
2. Man-in-the-middle (MitM) attack

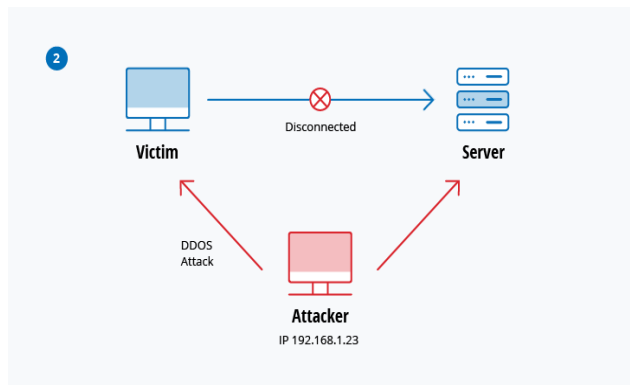
A MitM attack occurs when a hacker inserts itself between the communications of a client and a server. Here are some common types of man-in-the-middle attacks:

Session hijacking

In this type of MitM attack, an attacker hijacks a session between a trusted client and network server. The attacking computer substitutes its IP address for the trusted client while the server continues the session, believing it is communicating with the client. For instance, the attack might unfold like this:

1. A client connects to a server.
2. The attacker's computer gains control of the client.
3. The attacker's computer disconnects the client from the server.
4. The attacker's computer replaces the client's IP address with its own IP address and spoofs the client's sequence numbers.
5. The attacker's computer continues dialog with the server and the server believes it is still communicating with the client.





IP Spoofing

IP spoofing is used by an attacker to convince a system that it is communicating with a known, trusted entity and provide the attacker with access to the system. The attacker sends a packet with the IP source address of a known, trusted host instead of its own IP source address to a target host. The target host might accept the packet and act upon it.

Replay

A replay attack occurs when an attacker intercepts and saves old messages and then tries to send them later, impersonating one of the participants. This type can be easily countered with session timestamps or nonce (a random number or a string that changes with time).

Currently, there is no single technology or configuration to prevent all MitM attacks. Generally, encryption and digital certificates provide an effective safeguard against MitM attacks, assuring both the confidentiality and integrity of communications. But a man-in-the-middle attack can be injected into the middle of communications in such a way that encryption will not help — for example, attacker “A” intercepts public key of person “P” and substitute it with his own public key. Then, anyone wanting to send an encrypted message to P using P’s public key is unknowingly using A’s public key. Therefore, A can read the message intended for P and then send the message to P, encrypted in P’s real public key, and P will never notice that the message was compromised. In addition, A could also modify the message before resending it to P. As you can see, P is using encryption and thinks that his information is protected but it is not, because of the MitM attack.

So, how can you make sure that P’s public key belongs to P and not to A? Certificate authorities and hash functions were created to solve this problem. When person 2 (P2) wants to send a message to P, and P wants to be sure that A will not read or modify the message and that the message actually came from P2, the following method must be used:

1. P2 creates a symmetric key and encrypts it with P’s public key.
2. P2 sends the encrypted symmetric key to P.
3. P2 computes a hash function of the message and digitally signs it.
4. P2 encrypts his message and the message’s signed hash using the symmetric key and sends the entire thing to P.
5. P is able to receive the symmetric key from P2 because only he has the private key to decrypt the encryption.
6. P, and only P, can decrypt the symmetrically encrypted message and signed hash because he has the symmetric key.
7. He is able to verify that the message has not been altered because he can compute the hash of received message and compare it with digitally signed one.
8. P is also able to prove to himself that P2 was the sender because only P2 can sign the hash so that it is verified with P2 public key.

4. Drive-by attack

Drive-by download attacks are a common method of spreading malware. Hackers look for insecure websites and plant a malicious script into HTTP or PHP code on one of the pages. This script might install malware directly onto the computer of someone who visits the site, or it might re-direct the victim to a site controlled by the hackers. Drive-by downloads can happen when visiting a website or viewing an email message or a pop-up window. Unlike many other types of cyber security attacks, a drive-by doesn't rely on a user to do anything to actively enable the attack — you don't have to click a download button or open a malicious email attachment to become infected. A drive-by download can take advantage of an app, operating system or web browser that contains security flaws due to unsuccessful updates or lack of updates.

To protect yourself from drive-by attacks, you need to keep your browsers and operating systems up to date and avoid websites that might contain malicious code. Stick to the sites you normally use — although keep in mind that even these sites can be hacked. Don't keep too many unnecessary programs and apps on your device. The more plug-ins you have, the more vulnerabilities there are that can be exploited by drive-by attacks.

5. Password attack

Because passwords are the most commonly used mechanism to authenticate users to an information system, obtaining passwords is a common and effective attack approach. Access to a person's password can be obtained by looking around the person's desk, "sniffing" the connection to the network to acquire unencrypted passwords, using social engineering, gaining access to a password database or outright guessing. The last approach can be done in either a random or systematic manner:

- **Brute-force** password guessing means using a random approach by trying different passwords and hoping that one work. Some logic can be applied by trying passwords related to the person's name, job title, hobbies or similar items.
- In a **dictionary attack**, a dictionary of common passwords is used to attempt to gain access to a user's computer and network. One approach is to copy an encrypted file that contains the passwords, apply the same encryption to a dictionary of commonly used passwords, and compare the results.

In order to protect yourself from dictionary or brute-force attacks, you need to implement an account lockout policy that will lock the account after a few invalid password attempts. You can follow these account lockout best practices in order to set it up correctly.

8. Eavesdropping attack

Eavesdropping attacks occur through the interception of network traffic. By eavesdropping, an attacker can obtain passwords, credit card numbers and other confidential information that a user might be sending over the network. Eavesdropping can be passive or active:

- **Passive eavesdropping** — A hacker detects the information by listening to the message transmission in the network.
- **Active eavesdropping** — A hacker actively grabs the information by disguising himself as friendly unit and by sending queries to transmitters. This is called probing, scanning or tampering.

Detecting passive eavesdropping attacks is often more important than spotting active ones, since active attacks requires the attacker to gain knowledge of the friendly units by conducting passive eavesdropping before.

Data encryption is the best countermeasure for eavesdropping.

9. Birthday attack

Birthday attacks are made against hash algorithms that are used to verify the integrity of a message, software or digital signature. A message processed by a hash function produces a message digest (MD) of fixed length, independent of the length of the input message; this MD uniquely characterizes the message. The birthday attack refers to the probability of finding two random messages that generate the same MD when processed by a hash function. If an attacker calculates same MD for his message as the user has, he can safely replace the user's message with his, and the receiver will not be able to detect the replacement even if he compares MDs.

Eavesdropping Attack Defined

An eavesdropping attack, which are also known as a sniffing or snooping attack, is an incursion where someone tries to steal information that computers, smartphones, or other devices transmit over a network. An eavesdropping attack takes advantage of unsecured network communications to access the data being sent and received. Eavesdropping attacks are difficult to detect because they do not cause network transmissions to appear to be operating abnormally.

The term 'eavesdropping' is used to refer to the interception of communication between two parties by a malicious third party. Since the beginning of the digital age, the term has also come to hold great significance in the world of cyber security.

What is Eavesdropping Attack?

An attack where someone tries to steal information transmitted through digital devices. The attacker takes advantage of unsafe network communications and accesses sent and received data. These attacks are difficult to detect as no abnormality can be identified in network transmissions. It is also known as sniffing or snooping attack.

IP Spoofing

Attackers may use IP (Internet Protocol) spoofing to disguise a computer IP address, thereby hiding the identity of the sender or impersonating another computer system. One purpose of IP address spoofing is to gain access to a networks that authenticate users based on IP addresses.

More often, however, attackers will spoof a target's IP address in a denial-of-service attack to overwhelm the victim with traffic. The attacker will send packets to multiple network recipients, and when packet recipients transmit a response, they will be routed to the target's spoofed IP address.

IP spoofing is also called IP address forgery or host file hijack. It is a technique to get unauthorized access to computers (servers) where the attacker sends messages to a computer network with an IP address indicating that the message is coming from another IP host which is a trusted one. At first, the hacker needs to find the IP address of a trusted host and then modify the headers of the packets which are being sent, so that it appears to the computer that the packets are coming from that trusted host. However, modern hardware's used to establish the

network such as routers and firewalls could give protection from IP spoofing. As we've seen earlier, this is an attacking technique commonly used by the spammers and scammers to mislead others on the origin of the information they send.